

PRIVILEGE ESCALATION

Privilege escalation - scenario where an attacker gains higher access to a system or network than they are initially entitled to.

Incident Details	
Incident Name:	EventID: 313 - [SOC335 - CVE-2024-49138 Exploitation Detected]
Description:	EventID: 313
Incident Type:	Privilege Escalation
Created Date:	May, 22, 2025, 06:37 PM
Start Playbook!	

Event Time :	Jan, 22, 2025, 02:37 AM
Rule :	SOC335 - CVE-2024-49138 Exploitation Detected
Level :	Security Analyst
Hostname :	Victor
Ip Address :	172.16.17.207
Process Name :	svohost.exe
Process Path :	"C:\temp\service_installer\svohost.exe"
Process ID :	7640
Parent Process :	C:\Windows\System32\WINDOWSPOWERSHELL\1.0\powershell.exe
Command Line :	\??\C:\Windows\system32\conhost.exe 0xffffffff -ForceV1
File Hash :	b432dcf4a0f0b601b1d79848467137a5e25cab5a0b7b1224be9d3b6540122db9
Process User :	EC2AMAZ-ILGVOIN\LetsDefend
Trigger Reason :	Unusual or suspicious patterns of behavior linked to the hash have been identified, indicating potential exploitation of CVE-2024-49138.
Device Action :	Allowed
Show Hint ⚠	

Red flags with the event on the first look:

The svohost.exe process name mimics svchost.exe windows system file
The file hash was flagged for malicious behaviour
The device action shows allowed thus the threat might still be active

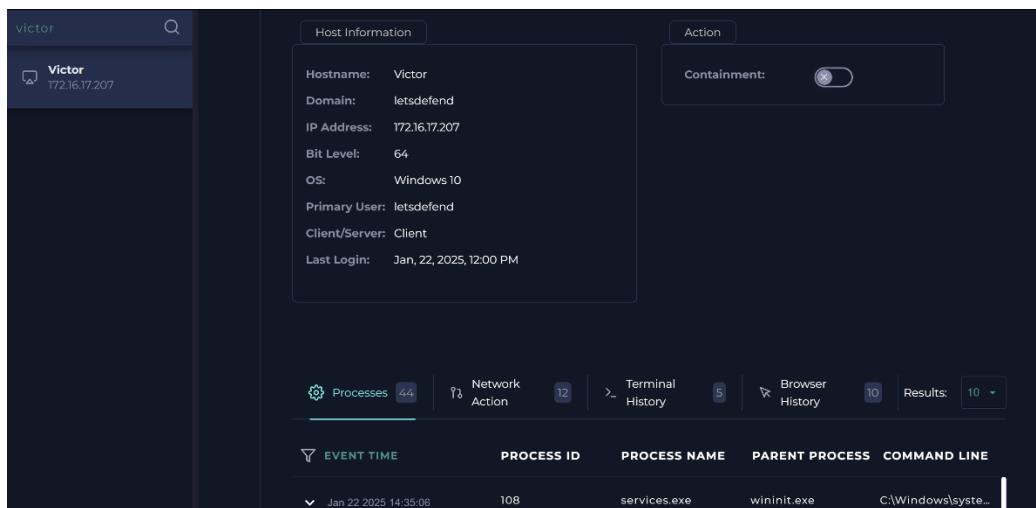
- Threat - potential danger
- Attack - actual execution of that threat

1. Threat Indicator:

- Unknown or unexpected outgoing internet traffic

2. Log Management – provides access to all logs in an environment and allows management in one place

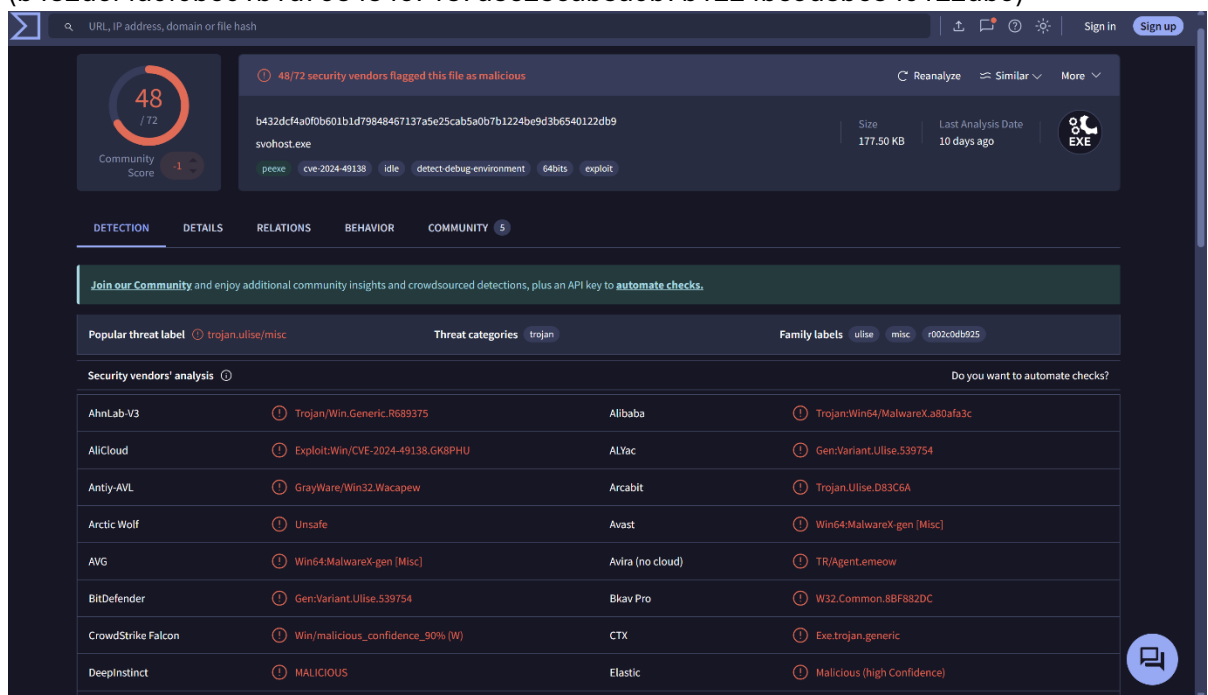
Endpoint Security – real-time monitoring of endpoint data and is used to isolate hacked machines from a network



- The malware is **not quarantined** as shown in the action bar

3. Analyze malware using multiple 3rd party tools

- Using VirusTotal run the hash
(b432dcf4a0f0b601b1d79848467137a5e25cab5a0b7b1224be9d3b6540122db9)



- Using URLhaus shows it is not malicious which proves the need to run the hash using multiple software to be sure.

The file is clearly malicious based on majority of the vendors

4. Check if someone requested C2 (command & control) -using log management

- Command and control infrastructure – used by attackers to maintain control/ persistence within the target environment. (explained in MITRE ATT&CK® framework)

Show Filter BasicPro Search						
DATE ↑	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Jan, 22, 2025, 02:35 PM	OS	185.107.56.141	0	172.16.17.207	0	🔍
Jan, 22, 2025, 02:35 PM	OS	185.107.56.141	0	172.16.17.207	0	🔍
Jan, 22, 2025, 02:35 PM	OS	185.107.56.141	0	172.16.17.207	0	🔍
Jan, 22, 2025, 02:35 PM	OS	185.107.56.141	0	172.16.17.207	0	🔍
Jan, 22, 2025, 02:35 PM	OS	185.107.56.141	0	172.16.17.207	0	🔍
Jan, 22, 2025, 02:35 PM	OS	185.107.56.141	0	172.16.17.207	0	🔍
Jan, 22, 2025, 02:35 PM	OS	185.107.56.141	0	172.16.17.207	0	🔍
Jan, 22, 2025, 02:35 PM	OS	185.107.56.141	0	172.16.17.207	0	🔍
Jan, 22, 2025, 02:35 PM	OS	185.107.56.141	0	172.16.17.207	0	🔍
Jan, 22, 2025, 02:35 PM	OS	185.107.56.141	0	172.16.17.207	0	🔍

This show s continuous access from the SRC address 185.107.56.141 therefore the C2 infrastructure was **accessed**

5. Contain the user machine

victor

Victor

172.16.17.207

Endpoint Information

Host Information

Hostname: Victor

Domain: letsdefend

IP Address: 172.16.17.207

Bit Level: 64

OS: Windows 10

Primary User: letsdefend

Client/Server: Client

Last Login: Jan, 22, 2025, 12:00 PM

Action

Containment:

☒

Host Contained

6. Close alert

Close Alert

Event ID :

313

☒ True Positive

☐ False Positive

Note:

The attack proved to be a true positive thus the host was contained

Close Alert